

Project APEX

Chapter 27 — Authentication & Authorization

27.1 Purpose

The Authentication & Authorization layer secures Project APEX by verifying identities and enforcing access policies across services, APIs, plugins, and user interfaces.

27.2 Objectives

- Identity verification
- Fine-grained access control
- Secure API access
- Multi-tenant isolation
- Auditability

27.3 Core Components

- Identity Provider (IdP)
- Authentication Service
- Authorization Engine
- Role & Permission Store
- Token Service
- Session Manager

27.4 Authentication Flow

User → Login → Identity Verification → Token Issuance → API Gateway → Backend Services → Resource Access.

27.5 Authorization Model

Authorization is enforced using roles, permissions, policies, and resource ownership. Every protected request is evaluated before access is granted.

27.6 Design Principles

- Zero-trust architecture
- Least privilege access
- Defense in depth
- Token-based authentication
- Centralized policy enforcement

27.7 Challenges

Managing identities across distributed services, preventing privilege escalation, handling token lifecycles, and maintaining low-latency authorization decisions.

27.8 Role in APEX

The security layer protects user data, workflow history, AI models, plugins, and administrative operations while enabling secure collaboration across the platform.

Security Component	Primary Responsibility
Identity Provider	Authenticate users
Token Service	Issue and validate tokens
Authorization Engine	Evaluate access policies
Role Store	Manage roles and permissions
Session Manager	Track active sessions
Audit Log	Record security events

27.9 Chapter Summary

Authentication & Authorization provide the trust foundation of Project APEX by ensuring that every identity is verified, every request is authorized, and every security-sensitive action is traceable.